

CVE-2024-5480 reported by security analyzers #129228

Open

cbornet opened on Jun 21, 2024

Contributor ...

Describe the bug

Security analyzers report a critical CVE: <https://www.cve.org/CVERecord?id=CVE-2024-5480>

Versions

2.2.2, 2.3.1

cbornet on Jun 21, 2024

Contributor Author ...

Because of <https://github.com/pytorch/pytorch/security/policy#using-distributed-features>, I'm not sure the CVE is relevant.

Can it be disputed if it is not ?

1

  **malfet** added **security** **triage review** on Jun 22, 2024

  **janeyx99** added **triaged** and removed **triage review** on Jun 25, 2024

  **janeyx99** assigned **malfet** on Jun 25, 2024

fcanogab on Jul 8, 2024

...

@cbornet, have you disputed this CVE? I don't see it disputed in the MITRE page <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-5480>.

cbornet on Jul 9, 2024

Contributor Author ...

No I haven't. I'd need confirmation that it is a false positive.
And it would probably be better if the maintainers did the dispute.

fcanogab on Jul 10, 2024

@malfet, will you dispute the CVE? If you don't consider it a security vulnerability per <https://github.com/pytorch/pytorch/security/policy#using-distributed-features>, it is recommended that you dispute it because that way security scanners won't detect this as an important security vulnerability which will generate unnecessary noise.

cbornet on Jul 10, 2024

Contributor

Author

The person who opened the CVE got a 1500\$ bounty : <https://huntr.com/bounties/39811836-c5b3-4999-831e-46fee8fcade3> ! Not bad if that's a false positive 😊 ...

jeanineharb on Jul 22, 2024

Hello, this CVE is still being reported for v2.3.1 (by [safety](#)). Any updates?

p-roq on Jul 24, 2024

IMHO this issue should never be classified as vulnerability with an official CVE id.

@cbornet already provided link to the official documentation:

<https://github.com/pytorch/pytorch/security/policy#using-distributed-features>

where is clearly written how the `torch.distributed` package works:

PyTorch Distributed features are intended for internal communication only. They are not built for use in untrusted environments or networks.

You can work with Mitre to dispute this CVE .

The CNA who assigned this CVE (in this case huntr.dev) should check documentation and discuss it wit PyTorch maintainers first.



sbarber2 mentioned this [on Aug 26, 2024](#)



[Create docs/source/security.md, ignoring CVE-2024-5480 Plant-Tracer/PlantTracerML#21](#)

hyandell on Oct 29, 2024

Noting that the CVE page now says:

"** [REJECT](#) ** This CVE ID has been rejected or withdrawn by its CVE Numbering Authority."

Hetti on Feb 26, 2025 · edited by Hetti

Edits

I'm reading this issue and I am wondering about the way how you are dealing with this security issue.

Writing down that a feature is unsecure in the documentation and rejecting a (IMHO valid) CVE because you stated that your feature is unsecure by default is not how you should do security.

I hope you rethink your security approach. PyTorch is a widely used software and implementing features unsafely is not responsible.

I really hope you gonna improve the distributed feature - that this feature is in the future not a complete security nightmare. No authorization - no validation - RCE. Every attacker in company networks loves this and there are also for sure some people that will run this publicly on the internet because they don't understand the implications.

4

1

  **redwrasse** mentioned this on Aug 23, 2025

✓ PyTorch Security Analysis: Prioritized Security Improvement Tasks #161327

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

 **malfet**

Labels

security **triaged**

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode 

No branches or pull requests

Participants

     +3

